

Penetration Testing Tools

Estimated time needed: 5 minutes

Learning objectives

- Describe penetration testing tools
- Categorize penetration testing tools and explain their functionality
- List the different tools in each category and illustrate their use in penetration testing

What are penetration testing tools?

Penetration or pen testing tools are software or frameworks used by security professionals to evaluate the security of networks, applications, and computer systems by simulating real-world cyberattacks. Their primary purpose is to help identify weaknesses in an organization's security defense before malicious attackers exploit them, enabling organizations to fix vulnerabilities and improve their security posture.

Based on their functionality, pen testing tools are categorized into seven types:

- Network scanning tools
- Exploitation tools
- Web application testing tools
- Wireless network testing tools
- Password cracking tools
- Traffic analysis tools
- Social engineering tools

Let's discuss each of these types in detail.

Network scanning tools

Network scanning tools scan and map networks to help ascertain potential vulnerabilities. They are used to discover devices on a network, identify open ports, and detect services running on those ports.

Here are three network scanning tools:

- **Nmap** (short for network mapper) is a network discovery and security auditing tool. It is used to identify open ports and services on a target network and find potential attack entry points. Nmap scans large networks to discover hosts and services, creating a network map.
Source: <https://nmap.org>
- **Nessus** is a scanner that helps identify vulnerabilities, misconfigurations, and compliance issues. It is used to scan networks for known vulnerabilities and generate detailed reports for remediation.
Source: <https://www.tenable.com/>
- **IBM QRadar** is a network security intelligence platform combining log management, threat detection, and cloud security. It is used to proactively identify vulnerabilities and security threats across network devices.
Source: <https://www.ibm.com/security/security-intelligence/qradar>

Exploitation tools

Exploitation tools leverage vulnerabilities in systems, applications, or networks. They help simulate real-world attacks to test the effectiveness of security defenses.

- **Metasploit** is a framework for developing, testing, and executing exploits against a target system. It simulates real-world attacks to test the effectiveness of security defenses and identify exploitable vulnerabilities.
Source: <https://www.metasploit.com/>
- **IBM X-Force Red** is an offensive security testing service that validates security solutions and responses. This service is provided by experts who conduct simulated attacks to identify and address vulnerabilities before they can be exploited, functioning as a proactive exploitation tool.
Source: <https://www.ibm.com/security/services/xforce-red>

Web application testing tools

Web application testing tools identify and exploit vulnerabilities in web applications, helping to protect them from common security risks.

- **Burp Suite** is an integrated platform that performs web application security testing. It includes tools for scanning, crawling, and exploiting web vulnerabilities. It identifies and exploits vulnerabilities in web applications, such as cross-site scripting (XSS) and structured query language (SQL) injection.
Source: <https://portswigger.net/burp>
- **Open Web Application Security Project Zed Attack Proxy (OWASP ZAP)** is an open-source security scanner that helps find security vulnerabilities in web applications. It is used both in automated and manual testing to identify security issues.
Source: <https://zapproxy.org>

Wireless network testing tools

Wireless network testing tools assess the security of wireless networks. They help identify weak encryption keys, unauthorized access points, and other vulnerabilities.

- **Aircrack-ng** is a toolset for assessing wifi network security. It includes tools for capturing packets, cracking wired equivalent privacy (WEP) and wifi-protected access pre-shared keys (WPA-PSK), and analyzing wifi traffic. Aircrack-ng tests the security of wireless networks by capturing and analyzing traffic to identify weak encryption keys.
Source: <https://www.aircrack-ng.org/>
- **Kismet** is a wireless network detector, protocol analyzer, and intrusion detection system. It detects and analyzes wireless networks and identifies unauthorized access points.
Source: <https://www.kismetwireless.net/>

Password cracking tools

Password cracking tools recover passwords from data stored or transmitted in a hashed or encrypted format. They help test the strength of password policies and identify weak passwords.

- **John the Ripper** is a fast password-cracking tool that supports various password hashes. It is used to crack passwords to test the strength of password policies and identify weak passwords.
Source: <https://www.openwall.com/john/>
- **Hashcat**, a tool for advanced password recovery, supports many hashing algorithms. It is used to perform brute-force attacks to crack hashed passwords and assess password security.
Source: <https://hashcat.net/hashcat/>

Traffic analysis tools

Traffic analysis tools capture and analyze network traffic. They help monitor network activity, identify suspicious behavior, and troubleshoot network issues.

- **Wireshark** is a network protocol analyzer that analyzes and captures real-time network traffic. It helps identify suspicious activity and troubleshoot network issues by monitoring network traffic.
Source: <https://www.wireshark.org/>
- **Tcpdump** or Transmission Control Protocol Dump, is a command-line packet analyzer that enables users to capture, display, and analyze network packets to identify potential security threats.
Source: <https://www.tcpdump.org/>

Social engineering tools

Social engineering tools simulate social engineering attacks, such as phishing and credential harvesting. They help test the effectiveness of security awareness training and identify vulnerabilities in human behavior.

- **Social-Engineer Toolkit (SET)** is a framework for simulating social engineering attacks and testing the effectiveness of security awareness training.
Source: <https://trustedsec.com/resources/tools/the-social-engineer-toolkit-set>
- **Maltego** is an open-source intelligence (OSINT) and forensics application that provides data mining and link analysis. It gathers information about a target through OSINT to support social engineering attacks.
Source: <https://www.maltego.com/>

Summary

In this reading, you learned about pen testing tools and how they can be used to improve the security posture of organizations.

- Pen testing tools are frameworks, software, or systems that assess the security of systems, networks, and applications by simulating attacks to identify and address vulnerabilities.
- There are seven categories of pen testing tools:
 - Network scanning tools map the network and identify potential vulnerabilities.
 - Exploitation tools simulate attacks to exploit vulnerabilities in systems or networks.
 - Web application testing tools identify and exploit vulnerabilities in web applications.
 - Wireless network testing tools assess the security of wireless networks.
 - Password cracking tools recover and test the strength of passwords.
 - Traffic analysis tools capture and analyze network traffic.
 - Social engineering tools simulate social engineering attacks.

Author(s)

Dee Dee Colette



Skills Network